

Chapter 04

2026 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드

보안 장비

1. 계정 관리	472
2. 접근 관리	484
3. 패치 관리	501
4. 로그 관리	507
5. 기능 관리	519

01 보안 장비 취약점 분석 · 평가 항목

1. 계정 관리

점검항목	항목 중요도	항목코드
보안 장비 Default 계정 변경	상	S-01
비밀번호 관리정책 설정	상	S-02
보안 장비 계정별 권한 설정	상	S-03
보안 장비 계정 관리	상	S-04
계정 잠금 임계값 설정	상	S-05

2. 접근 관리

점검항목	항목 중요도	항목코드
보안장비 원격 관리 접근 통제	상	S-06
보안장비 보안 접속	상	S-07
세션 종료 시간 설정	상	S-08

3. 패치 관리

점검항목	항목 중요도	항목코드
주기적 보안 패치 및 벤더 권고사항 적용	상	S-09

04. 보안 장비

4. 로그 관리

점검항목	항목 중요도	항목코드
보안장비 로그 설정	중	S-10
보안장비 로그 보관	중	S-11
보안장비 정책 백업 설정	중	S-12
원격 로그 서버 사용	중	S-13
NTP 및 시각 동기화 설정	중	S-14

5. 기능 관리

점검항목	항목 중요도	항목코드
정책 관리	상	S-15
NAT 설정	상	S-16
DMZ 설정	상	S-17
최소한의 서비스만 제공	상	S-18
이상징후 탐지 모니터링 수행	상	S-19
장비 사용량 검토	상	S-20
SNMP 서비스 확인	상	S-21
SNMP Community String 복잡성 설정	상	S-22
유해 트래픽 탐지/차단 정책 설정	중	S-23

S-01 (상)	보안 장비 > 1. 계정 관리
	보안장비 Default 계정 변경
개요	
점검 내용	보안 장비에 기본적으로 설정된 관리자 계정의 변경 여부 점검
점검 목적	보안 장비의 기본 관리자 계정정보는 인터넷이나 매뉴얼 등에 공개되어 있으므로 보안 장비의 기본 관리자 계정을 변경하여 비인가자가 기본 관리자 계정을 통한 보안 장비 접근을 방지하기 위함
보안 위협	보안 장비의 기본 관리자 계정을 변경하지 않을 경우, 비인가자가 공개된 기본 관리자 계정정보를 통하여 보안 장비에 불법적인 접근 및 보안 장비 설정값을 변경함으로써 시스템 침입 경로 제공 및 보안 장비를 무력화할 수 있는 위험이 존재함
참고	※ 기본 계정 : 장비 제조업체에서 출고 시 설정되어 나오는 기본 관리자 계정정보
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 장비에서 제공하고 있는 기본 계정을 변경하여 사용하는 경우 (기본 계정 변경이 불가능할 경우 기본 비밀번호 변경으로 보완 필요)
	취약 : 장비에서 제공하고 있는 기본 계정을 변경할 수 있으나 변경하지 않고 사용하는 경우
조치 방법	기본 계정 변경
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) Web을 통한 접속

Step 1) 기본 계정, 비밀번호 입력

Step 2) 접속 확인

Username:

Password:

Login

[접속 확인]

04. 보안 장비

Step 2) 보안 장비에서 제공하고 있는 계정 메뉴에서 기본 계정 변경

The screenshot shows a web interface for user management. At the top, it says 'Defined by' and 'USER'. Below this, there is a 'Disabled' status indicator with a red icon and a checkbox. The 'Username' field is highlighted with a red rectangle, and next to it is a 'ChangeUser' button. Below the 'Username' field is a 'Password' field, followed by a confirmation field labeled '(confirmation)'. At the bottom, there is a checkbox labeled 'Generate a scrambled password to prevent local database logins for this user.'.

[기본 계정 변경]

Step 3) 기본 계정 변경이 불가능할 경우 기본 비밀번호 변경으로 보완 필요

S-02 (상)	보안 장비 > 1. 계정 관리
	비밀번호 관리정책 설정
개요	
점검 내용	보안 장비의 계정 비밀번호가 기관 정책에서 정의된 비밀번호 관리 정책 적용 여부 점검
점검 목적	비밀번호 관리 정책에 적용 여부를 점검하여 비인가자의 비밀번호 추측 공격(무차별 대입 공격, 사전 대입 공격 등)에 대비가 되어있는지 확인하기 위함
보안 위협	비밀번호 관리 정책에 맞지 않는 비밀번호를 사용할 경우, 비인가자의 비밀번호 추측 공격(무차별 대입 공격, 사전 대입 공격 등)에 계정 비밀번호가 유출되어 비인가자가 보안 장비에 접근할 위험이 존재함
참고	※ 비밀번호 관리 정책 : 기관 정책에서 정의된 비밀번호 복잡성, 비밀번호 최소 길이, 비밀번호 최소 사용기간, 비밀번호 최대 사용기간 ※ 무차별 대입 공격(Brute Force Attack) : 컴퓨터로 암호를 해독하기 위해 가능한 모든 키를 하나하나 추론해 보는 시도 ※ 사전 대입 공격(Dictionary Attack) : 사전에 있는 단어를 입력하여 비밀번호를 알아내거나 암호를 해독하는 데 사용되는 컴퓨터 공격 방법
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 비밀번호 관리 정책에 맞는 비밀번호가 사용된 경우
	취약 : 비밀번호 관리 정책에 맞지 않는 비밀번호가 사용된 경우
조치 방법	해당 기관의 비밀번호 관리 정책에 따라 적합하게 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) Web을 통한 접속

Step 2) 기본 계정, 비밀번호 입력

04. 보안 장비

Step 3) 접속 확인



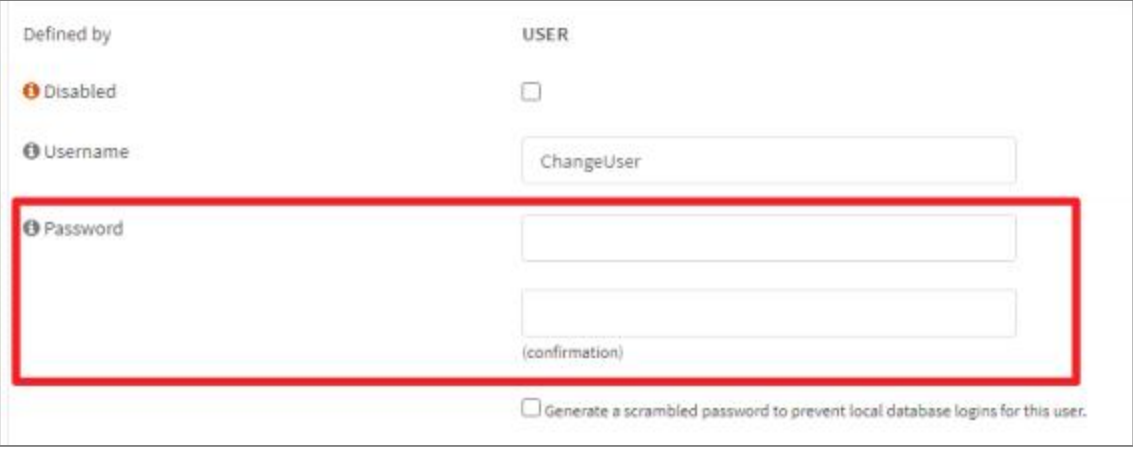
Username:

Password:

Login

[접속 확인]

Step 4) 비밀번호 메뉴에서 비밀번호 변경



Defined by USER

Disabled ☐

Username ChangeUser

Password

(confirmation)

☐ Generate a scrambled password to prevent local database logins for this user.

[기본 비밀번호 변경]

Step 5) 보안 장비가 제공하는 범위에서 비밀번호 관리 정책에 맞는 비밀번호로 변경

복잡성 및 최소 길이 : 특수문자, 숫자, 영 소문자 포함 8자리 이상, 최소 사용기간(1일) 설정

S-03 (상)	보안 장비 > 1. 계정 관리
	보안장비 계정별 권한 설정
개요	
점검 내용	보안 장비에 등록된 계정들에 대해 업무에 불필요한 권한 여부 점검
점검 목적	보안 장비에 등록된 계정의 용도별 권한을 부여함으로써 권한 없는 사용자의 설정 변경으로 인한 시스템 침입 경로 유출 위험을 줄이고 관리자 계정이 아닌 일반 계정이 비인가자에게 탈취되었을 때 보안 장비를 장악하지 못하게 하기 위함
보안 위협	사용자별 계정의 용도 파악 및 적절한 권한을 부여하지 않을 경우, 권한 없는 사용자의 의도하지 않은 보안 정책 수정이나 보안 장비 설정값 변경을 통하여 비인가자에게 시스템 침입 경로를 제공할 위험이 존재함
참고	※ 관리자 권한은 최소한의 계정에만 부여
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 사용자별 계정의 용도 파악 및 적절한 권한이 부여된 경우
	취약 : 사용자별 계정의 용도 파악 및 적절한 권한이 부여되지 않은 경우
조치 방법	사용자별 계정의 용도 파악 및 적절한 권한 부여
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비에서 제공하고 있는 계정 메뉴에서 계정별 권한 확인



[계정 권한 확인]

Step 2) 보안 장비에서 제공하고 있는 계정 메뉴에서 기존 계정의 권한 검토(불필요한 권한 삭제)

Step 3) 단일 계정을 여러 사용자가 공유 시 사용자별 계정 생성 및 권한 차등 부여

04. 보안 장비

S-04 (상)	보안 장비 > 1. 계정 관리
	보안장비 계정 관리
개요	
점검 내용	보안 장비에 등록된 계정 중 사용하지 않는 계정을 제거 또는 관리 여부 점검
점검 목적	사용하지 않는 불필요한 계정을 관리함으로써 관리되지 않은 계정을 통한 공격을 차단하기 위함
보안 위협	불필요한 계정을 제거하지 않거나 관리하지 않을 경우, 비인가자의 공격을 통해 불필요한 계정 탈취의 위험이 존재함
참고	※ 공용 계정 및 휴면계정의 계정 탈취 시 침해사고 발생 후 사후 추적이 어려움
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 불필요한 계정을 제거하거나 관리된 경우
	취약 : 불필요한 계정을 제거하지 않거나 관리되지 않은 경우
조치 방법	불필요한 공용 계정 및 휴면계정 제거
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비에서 제공하고 있는 계정 메뉴에서 계정 및 담당자 확인

Username	Full name	Groups
KISA	KISA	normal_group
root	System Administrator	admins

System Administrator Disabled User Normal User

[계정 확인]

Step 2) 사용하지 않는 계정 삭제

Step 1) 공용 계정 사용 시 사용자별 계정 생성 및 시스템 접근 이력을 관리하여 책임 추적성 확보

※ 시스템이 아닌 사람을 중심으로 하는 통합된 계정 관리가 중요함

S-05 (상)	보안 장비 > 1. 계정 관리
	계정 잠금 임계값 설정
개요	
점검 내용	보안 장비에서 제공하고 있는 로그인 실패 임계값 설정 적용 여부 점검
점검 목적	보안 장비에서 제공하는 로그인 실패 임계값 설정을 통해 비인가자의 자동화된 방법을 이용한 비밀번호 추측 공격을 막기 위함
보안 위협	로그인 실패 임계값 설정을 적용하지 않을 경우, 비인가자는 자동화된 방법을 통하여 모든 계정에 대해 비밀번호 추측 공격을 자유롭게 시도하여 비밀번호 정보가 유출될 위험이 존재함
참고	※ 기종에 따라 Limited/Lockout로 표시됨 ※ 보안 장비에 계정 잠금 시간 기능을 지원할 시 함께 설정하면 보안성이 향상됨
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 로그인 실패 임계값을 5회 이하로 설정된 경우
	취약 : 로그인 실패 임계값을 5회 이하로 설정되지 않은 경우
조치 방법	로그인 실패 임계값을 5회 이하로 제한
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비에서 제공하고 있는 계정 메뉴에서 로그인 실패 임계값 확인

Step 2) 보안 장비에서 제공하고 있는 계정 메뉴에서 로그인 실패 임계값을 5회 이하로 설정

연속 로그인 실패 허용 횟수

5 회 ?

로그인 실패 처리방법

☒ 계정 잠금
 ☐ 영구 잠금 ?

계정 잠금 시간

60 분

[로그인 임계값 확인]

04. 보안 장비

S-06 (상)	보안 장비 > 2. 접근 관리
	보안 장비 원격 관리 접근 통제
개요	
점검 내용	보안 장비 원격 관리 시 관리자 IP 또는 특정 IP만 접근할 수 있도록 설정하였는지 점검
점검 목적	보안 장비에 원격으로 접근할 수 있는 특정 IP를 등록함으로써 비인가자의 보안 장비 접근을 차단하기 위함
보안 위협	보안 장비 원격 관리 시 특정 IP만 접근할 수 있도록 설정하지 않을 경우, 외부에 있는 비인가자가 탈취한 계정을 통해 보안 장비에 접근할 수 있게 되어 보안 장비 설정값을 변경하여 보안 장비를 무력화시킬 위험이 존재함
참고	※ 보안 장비에서 제공하는 관리자 접근제한 기능을 통해 관리자 단말기 또는 콘솔 장비의 허용된 IP만을 등록하고 접근을 제한할 수 있음 ※ 보안 장비 원격 관리를 원칙적으로 금지하나, 부득이 사용해야 하는 경우 원격 접속을 허용할 IP나 계정을 제한하는 등 보안대책을 세워 관리해야 함
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 원격 관리 시 관리자 IP 또는 특정 IP만 접근할 수 있도록 설정된 경우
	취약 : 원격 관리 시 관리자 IP 또는 특정 IP만 접근할 수 있도록 설정되지 않은 경우
조치 방법	원격 관리 시 관리자 및 특정 IP만 접근 허용
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비에서 제공하고 있는 메뉴에서 접속 IP나 계정 제한 확인

Step 2) 특정 IP나 계정에서만 접속할 수 있도록 설정

로그인 허용 IPv4 주소 (?) IPv4 + (Max 20)

1.1.1.1 ✖

2.2.2.2 ✖

로그인 허용 IPv6 주소 (?) IPv6 + (Max 20)

[IP 접근 제어]

S-07 (상)	보안 장비 > 2. 접근 관리
	보안장비 보안 접속
개요	
점검 내용	보안 장비 접속 시 암호화 프로토콜을 이용한 접속 여부 점검
점검 목적	보안 장비 접속 시 평문을 전송하는 Telnet, HTTP 접속을 사용하지 않고 데이터가 암호화되는 SSH, SSL 인증 등의 암호화 접속을 통하여 비인가자의 데이터 스니핑에 대비하기 위함
보안 위협	보안 장비 접속 시 암호화 통신을 하지 않을 경우, 데이터가 평문으로 전송되어 비인가자가 관리자 계정을 탈취할 위험이 존재함
참고	※ 스니핑(임의 지정) : 컴퓨터 네트워크상에 흘러 다니는 트래픽을 도청하는 행위 ※ SSL(Secure Socket Layer) : 웹사이트와 브라우저 사이에 전송되는 데이터를 암호화하여 인터넷 연결을 보호하기 위한 표준 기술 ※ 보안 장비에 대한 원격 접속을 원칙적으로 금지하나, 부득이 원격 접속을 해야 하는 경우 암호화 통신 프로토콜 사용 등 보안대책을 세워 접속해야 함
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 보안 장비 접속 시 암호화 통신을 하는 경우
	취약 : 보안 장비 접속 시 암호화 통신을 하지 않는 경우
조치 방법	보안 장비 접속 시, 가능하다면 SSL 등의 암호화 접속 활용
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) HTTPS 또는 SSH를 통한 접속 확인



[보안 장비 접속 확인]

Step 2) 보안 장비 접속 시, SSL, HTTPS 등의 암호화 접속 활용

※ 제품마다 상이하므로 벤더사에 문의

04. 보안 장비

S-08 (상)	보안 장비 > 2. 접근 관리
	세션 종료 시간 설정
개요	
점검 내용	보안 장비의 정책에 Session Timeout 설정을 적용하였는지 점검
점검 목적	보안 장비 관리 작업 완료 후 사용자의 부주의로 계정이 접속한 상태로 방치되는 경우를 방지하며 사용하지 않는 세션을 종료하여 가용성을 높이기 위함
보안 위협	Session Timeout 설정을 하지 않을 경우, 보안 장비에 접속한 사용자가 자리 이탈 또는 불완전한 세션 종료로 인해 권한이 없는 사용자가 해당 세션을 재사용하여 인증 없이 보안 장비에 접근함으로써 보안 정책 변경 및 삭제 등 악의적인 행위를 할 위험이 존재함
참고	※ Session Timeout : 로컬 또는 원격에서 보안 장비에 접속한 사용자가 일정 시간 동안 통신이 없을 시 해당 세션을 종료시키는 설정 ※ 보안 장비에 접속하여 이행하는 업무 특성을 고려하여 시간을 설정하도록 함
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : Session Timeout을 설정한 경우
	취약 : Session Timeout을 설정하지 않은 경우
조치 방법	Session Timeout 시간을 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

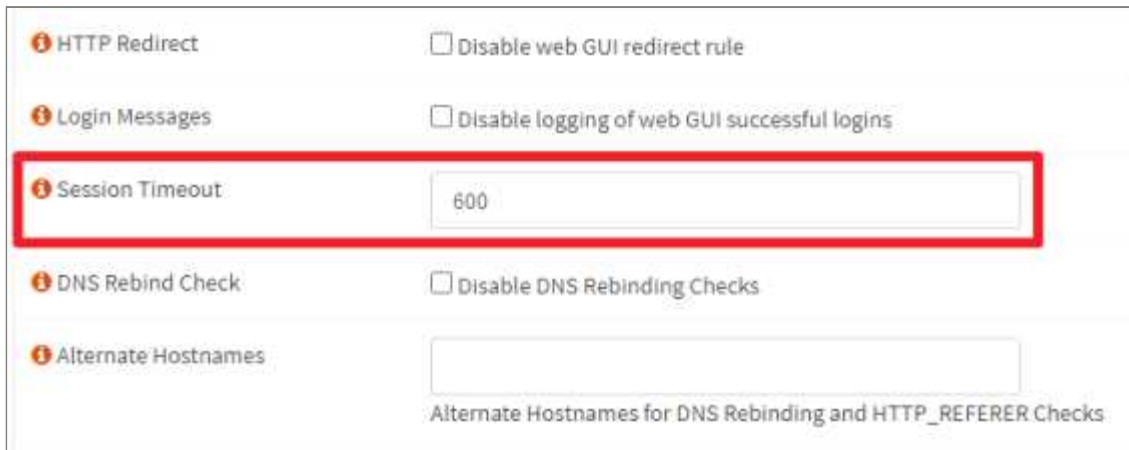
Step 1) 벤더별 설정값 확인. 대부분의 보안 장비는 기본으로 설정되어 있음

Step 2) Console, SSL, VPN, SSH 등의 모든 원격 접근에 대한 Session Timeout 설정 확인

The screenshot shows a configuration page for a security device. The 'Session Timeout' field is highlighted with a red rectangle and contains the value '240'. Other settings visible include 'HTTP Redirect', 'Login Messages', 'DNS Rebind Check', and 'Alternate Hostnames'.

[Session timeout 확인]

Step 3) 보안 장비가 제공하는 Session Timeout 기능 활성화 설정



The screenshot displays a configuration interface for a security device. It features several settings, each with an information icon (i) on the left and a checkbox on the right. The 'Session Timeout' setting is highlighted with a red rectangular box. The value '600' is entered in the text field next to it. Below the highlighted section, there is a label 'Alternate Hostnames for DNS Rebinding and HTTP_REFERER Checks'.

HTTP Redirect	☐ Disable web GUI redirect rule
Login Messages	☐ Disable logging of web GUI successful logins
Session Timeout	600
DNS Rebind Check	☐ Disable DNS Rebinding Checks
Alternate Hostnames	

Alternate Hostnames for DNS Rebinding and HTTP_REFERER Checks

[Session Timeout 설정]

04. 보안 장비

S-09 (상)	보안 장비 > 3. 패치 관리
	주기적 보안 패치 및 벤더 권고사항 적용
개요	
점검 내용	보안 장비 OS 및 보안 기능(IPS, 안티바이러스 등)을 주기적으로 보안 패치 여부 점검
점검 목적	주기적인 보안 패치를 통해 보안 장비 OS 취약점으로 발생하는 공격이나 보안 장비로 유입되는 최신 유해 트래픽에 대한 탐지 및 차단할 하기 위함
보안 위협	주기적 보안 패치 및 벤더 권고사항을 적용하지 않을 경우, 보안 장비 OS의 취약점을 이용한 공격이나 최신 유해 트래픽에 대한 탐지 및 차단이 제대로 이루어지지 않아 비인가자의 내부 정보시스템 침해 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 주기적 보안 패치 및 벤더 권고사항이 적용된 경우
	취약 : 주기적 보안 패치 및 벤더 권고사항이 적용되지 않은 경우
조치 방법	벤더사에서 주기적으로 제공하는 장비별 최신 취약점 정보를 파악 후 최신 패치 및 업그레이드를 수행
조치 시 영향	최신 업데이트 적용 시 시스템 재시작 등의 서비스 영향도 검토 필요

점검 및 조치 사례

● 공통

Step 1) 보안 장비의 최신 패치 현황 파악 또는 벤더사에 문의하여 최신 패치 현황 파악

Step 2) 주기적으로 업데이트 필요성에 대한 검토 및 조치를 하고 있는지 문서(정기점검보고서, 검토보고서, 작업계획서 등)를 통해 검토

Step 3) 자동 패치 기능 설정 또는 벤더사에 문의하여 수동으로 패치 수행

자동 업데이트 ☒ 사용

☒ 업데이트 주기 30 일 [지금 업데이트](#)

☐ 업데이트 일정 선택 +

현재 버전 : 2.7.5.23(Build 1070) (이전 버전 : 2.7.5.13(Build 1015) [목록](#))

현재 설정 ☒ 유지

필요한 파일 선택된 파일 없음 [업데이트](#)

[수동 및 자동 패치]

S-10 (중)	보안 장비 > 4. 로그 관리
	보안장비 로그 설정
개요	
점검 내용	보안 장비에 로그 설정이 적용되어 있는지 확인하고 로그 정책이 기관 정책에 맞게 적용되어 있는지 점검
점검 목적	로그 설정을 점검하여 보안 장비의 이상 유무와 보안 장비 및 보안 장비를 통해 보호받고 있는 정보시스템에 대한 비인가자의 침입 및 공격을 식별하고 있는지 확인하기 위함
보안 위협	로그 설정이 적용되어 있지 않을 경우, 보안 장비에 장애가 발생하거나 침해사고가 발생했을 경우 원인 분석이 어려운 위험이 존재함
참고	※ 로그 정책 설정: 로그 정책 설정 시 보안 장비에 대한 접근 이력(날짜, 시간, IP, ID, 명령어 이력 등), 보안 장비 성능 이상 유무(CPU, RAM 사용량 등), 보안 장비를 통해 유입되거나 외부로 나가는 트래픽에 대해 로그가 남도록 설정하는 것을 권장
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 기관 정책에 따른 로그 설정된 경우
	취약 : 기관 정책에 따른 로그 설정이 되지 않은 경우
조치 방법	기관 정책에 따른 로깅 설정
조치 시 영향	세부적인 로깅 설정은 보안 장비 성능에 영향을 미칠 수 있음

점검 및 조치 사례

● 공통

Step 1) 보안 장비의 로그 설정 메뉴 확인

Step 2) 기관 정책에 따른 로깅 설정 (각 벤더별 설정 방법이 상이함)

System: Settings: Logging

LocalRemoteStatistics

QSearch

SourceName	SourceId	SourceInstance	State	Type	Number	Description
global	scratch_buffers_count	a	queued	1		
destination	d_local_audit	a	processed	252		
destination	d_local_npd	a	processed	108		
destination	d_local_portalauth	a	processed	0		
destination	d_config_changed_e...	a	processed	4		
global	internal_source	a	dropped	0		
global	internal_source	a	processed	8		

12345678910111213141516171819202122232425262728293031323334353637383940414243444546474849505152535455565758596061626364656667686970717273747576777879808182838485868788899091929394959697989910010110210310410510610710810911011111211311411511611711811912012112212312412512612712812913013113213313413513613713813914014114214314414514614714814915015115215315415515615715815916016116216316416516616716816917017117217317417517617717817918018118218318418518618718818919019119219319419519619719819920020120220320420520620720820921021121221321421521621721821922022122222322422522622722822923023123223323423523623723823924024124224324424524624724824925025125225325425525625725825926026126226326426526626726826927027127227327427527627727827928028128228328428528628728828929029129229329429529629729829930030130230330430530630730830931031131231331431531631731831932032132232332432532632732832933033133233333433533633733833934034134234334434534634734834935035135235335435535635735835936036136236336436536636736836937037137237337437537637737837938038138238338438538638738838939039139239339439539639739839940040140240340440540640740840941041141241341441541641741841942042142242342442542642742842943043143243343443543643743843944044144244344444544644744844945045145245345445545645745845946046146246346446546646746846947047147247347447547647747847948048148248348448548648748848949049149249349449549649749849950050150250350450550650750850951051151251351451551651751851952052152252352452552652752852953053153253353453553653753853954054154254354454554654754854955055155255355455555655755855956056156256356456556656756856957057157257357457557657757857958058158258358458558658758858959059159259359459559659759859960060160260360460560660760860961061161261361461561661761861962062162262362462562662762862963063163263363463563663763863964064164264364464564664764864965065165265365465565665765865966066166266366466566666766866967067167267367467567667767867968068168268368468568668768868969069169269369469569669769869970070170270370470570670770870971071171271371471571671771871972072172272372472572672772872973073173273373473573673773873974074174274374474574674774874975075175275375475575675775875976076176276376476576676776876977077177277377477577677777877978078178278378478578678778878979079179279379479579679779879980080180280380480580680780880981081181281381481581681781881982082182282382482582682782882983083183283383483583683783883984084184284384484584684784884985085185285385485585685785885986086186286386486586686786886987087187287387487587687787887988088188288388488588688788888989089189289389489589689789889990090190290390490590690790890991091191291391491591691791891992092192292392492592692792892993093193293393493593693793893994094194294394494594694794894995095195295395495595695795895996096196296396496596696796896997097197297397497597697797897998098198298398498598698798898999099199299399499599699799899910001001100210031004100510061007100810091010101110121013101410151016101710181019102010211022102310241025102610271028102910301031103210331034103510361037103810391040104110421043104410451046104710481049105010511052105310541055105610571058105910601061106210631064106510661067106810691070107110721073107410751076107710781079108010811082108310841085108610871088108910901091109210931094109510961097109810991100110111021103110411051106110711081109111011111112111311141115111611171118111911201121112211231124112511261127112811291130113111321133113411351136113711381139114011411142114311441145114611471148114911501151115211531154115511561157115811591160116111621163116411651166116711681169117011711172117311741175117611771178117911801181118211831184118511861187118811891190119111921193119411951196119711981199120012011202120312041205120612071208120912101211121212131214121512161217121812191220122112221223122412251226122712281229123012311232123312341235123612371238123912401241124212431244124512461247124812491250125112521253125412551256125712581259126012611262126312641265126612671268126912701271127212731274127512761277127812791280128112821283128412851286128712881289129012911292129312941295129612971298129913001301130213031304130513061307130813091310131113121313131413151316131713181319132013211322132313241325132613271328132913301331133213331334133513361337133813391340134113421343134413451346134713481349135013511352135313541355135613571358135913601361136213631364136513661367136813691370137113721373137413751376137713781379138013811382138313841385138613871388138913901391139213931394139513961397139813991400140114021403140414051406140714081409141014111412141314141415141614171418141914201421142214231424142514261427142814291430143114321433143414351436143714381439144014411442144314441445144614471448144914501451145214531454145514561457145814591460146114621463146414651466146714681469147014711472147314741475147614771478147914801481148214831484148514861487148814891490149114921493149414951496149714981499150015011502150315041505150615071508150915101511151215131514151515161517151815191520152115221523152415251526152715281529153015311532153315341535153615371538153915401541154215431544154515461547154815491550155115521553155415551556155715581559156015611562156315641565156615671568156915701571157215731574157515761577157815791580158115821583158415851586158715881589159015911592159315941595159615971598159916001601160216031604160516061607160816091610161116121613161416151616161716181619162016211622162316241625162616271628162916301631163216331634163516361637163816391640164116421643164416451646164716481649165016511652165316541655165616571658165916601661166216631664166516661667166816691670167116721673167416751676167716781679168016811682168316841685168616871688168916901691169216931694169516961697169816991700170117021703170417051706170717081709171017111712171317141715171617171718171917201721172217231724172517261727172817291730173117321733173417351736173717381739174017411742174317441745174617471748174917501751175217531754175517561757175817591760176117621763176417651766176717681769177017711772177317741775177617771778177917801781178217831784178517861787178817891790179117921793179417951796179717981799180018011802180318041805180618071808180918101811181218131814181518161817181818191820182118221823182418251826182718281829183018311832183318341835183618371838183918401841184218431844184518461847184818491850185118521853185418551856185718581859186018611862186318641865186618671868186918701871187218731874187518761877187818791880188118821883188418851886188718881889189018911892189318941895189618971898189919001901190219031904190519061907190819091910191119121913191419151916191719181919192019211922192319241925192619271928192919301931193219331934193519361937193819391940194119421943194419451946194719481949195019511952195319541955195619571958195919601961196219631964196519661967196819691970197119721973197419751976197719781979198019811982198319841985198619871988198919901991199219931994199519961997199819992000200120022003200420052006200720082009201020112012201320142015201620172018201920202021202220232024202520262027202820292030203120322033203420352036203720382039204020412042204320442045204620472048204920502051205220532054205520562057205820592060206120622063206420652066206720682069207020712072207320742075207620772078207920802081208220832084208520862087208820892090209120922093209420952096209720982099210021012102210321042105210621072108210921102111211221132114211521162117211821192120212121222123212421252126212721282129213021312132213321342135213621372138213921402141214221432144214521462147214821492150215121522153215421552156215721582159216021612162216321642165216621672168216921702171217221732174217521762177217821792180218121822183218421852186218721882189219021912192219321942195219621972198219922002201220222032204220522062207220822092210221122122213221422152216221722182219222022212222222322242225222622272228222922302231223222332234223522362237223822392240224122422243224422452246224722482249225022512252225322542255225622572258225922602261226222632264226522662267226822692270227122722273227422752276227722782279228022812282228322842285228622872288228922902291229222932294229522962297229822992300230123022303230423052306230723082309231023112312231323142315231623172318231923202321232223232324232523262327232823292330233123322333233423352336233723382339234023412342234323442345234623472348234923502351235223532354235523562357235823592360236123622363236423652366236723682369237023712372237323742375237623772378237923802381238223832384238523862387238823892390239123922393239423952396239723982399240024012402240324042405240624072408240924102411241224132414241524162417241824192420242124222423242424252426242724282429243024312432243324342435243624372438243924402441244224432444244524462447244824492450245124522453245424552456245724582459246024612462246324642465246624672468246924702471247224732474247524762477247824792480248124822483248424852486248724882489249024912492249324942495249624972498249925002501250225032504250525062507250825092510251125122513251425152516251725182519252025212522252325242525252625272528252925302531253225332534253525362537253825392540254125422543254425452546254725482549255025512552255325542555255625572558255925602561256225632564256525662567256825692570257125722573257425752576257725782579258025812582258325842585258625872588258925902591259225932594259525962597259825992600260126022603260426052606260726082609261026112612261326142615261626172618261926202621262226232624262526262627262826292630263126322633263426352636263726382639264026412642264326442645264626472648264926502651265226532654265526562657265826592660266126622663266426652666266726682669267026712672267326742675267626772678267926802681268226832684268526862687268826892690269126922693269426952696269726982699270027012702270327042705270627072708270927102711271227132714271527162717271827192720272127222723272427252726272727282729273027312732273327342735273627372738273927402741274227432744274527462747274827492750275127522753275427552756275727582759276027612762276327642765276627672768276927702771277227732774277527762777277827792780278127822783278427852786278727882789279027912792279327942795279627972798279928002801280228032804280528062807280828092810281128122813281428152816281728182819282028212822282328242825282628272828282928302831283228332834283528362837283828392840284128422843284428452846284728482849285028512852285328542855285628572858285928602861286228632864286528662867286828692870287128722873287428752876287728782879288028812882288328842885288628872888288928902891289228932894289528962897289828992900290129022903290429052906290729082909291029112912291329142915291629172918291929202921292229232924292529262927292829292930293129322933293429352936293729382939294029412942294329442945294629472948294929502951295229532954295529562957295829592960296129622963296429652966296729682969297029712972297329742975297629772978297929802981298229832984298529862987298829892990299129922993299429952996299729982999300030013002300330043005300630073008300930103011301230133014301530163017301830193020302130223023302430253026302730283029303030313032303330343035303630373038303930403041304230433044304530463047304830493050305130523053305430553056305730583059306030613062306330643065306630673068306930703071307230733074307530763077307830793080308130823083308430853086308730883089309030913092309330943095309630973098309931003101310231033104310531063107310831093110311131123113311431153116311731183119312031213122312331243125312631273128312931303131313231333134313531363137313831393140314131423143314431453146314731483149315031513152315331543155315631573158315931603161316231633164316531663167316831693170317131723173317431753176317731783179318031813182318331843185318631873188318931903191319231933194319531963197319831993200320132023203320432053206320732083209321032113212321332143215321632173218321932203221322232233223432253226322732283229323032313232323332343235323632373238323932403241324232433244324532463247324832493250325132523253325432553256325732583259326032613262326

[로깅 설정]

04. 보안 장비

S-11 (중)	보안 장비 > 4. 로그 관리
	보안장비 로그 보관
개요	
점검 내용	로그 보관 정책에 따라 적절하게 로그를 보관하는지 점검
점검 목적	로그 보관 설정을 점검하여 로그 검토나 보안 장비 침해사고 원인 분석에 필요한(3개월 이상) 로그를 안전(삭제, 변경 불가)하게 보관하는지 확인하기 위함
보안 위협	로그 보관 기간이 적용되어 있지 않을 경우, 보안 장비에서 로그를 자동으로 삭제하여 로그 검토나 보안 장비 침해사고 원인 분석 시 필요한 로그가 남아 있지 않아 로그 검토나 사고 원인 분석이 어려워질 위험이 존재함
참고	※ 로그 보관 기간 : 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제45조 제2항에 따른 과학기술정보통신부 고시 「정보보호조치에 관한 지침 [별표1] 보호조치의 구체적인 내용 2.2.10 로그관리」에 따라 최소 1개월 이상 로그 기록 유지·관리(정보보호시스템은 3개월)하도록 정함
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 정책에 따라 로그 보관 설정된 경우
	취약 : 로그 보관 정책이 없고 관리되지 않은 경우
조치 방법	보안 장비 로그를 정기적으로 분석 및 검토
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비의 보관된 로그 날짜 확인

Step 2) 보안 장비 로그 보관 설정에서 로그 저장기간 확인 및 변경

(별도의 장비에 보관하고 있다면 로그 보관 정책에 맞게 보관 설정)

※ 각 벤더마다 설정 방법 상이

S-12 (중)	보안 장비 > 4. 로그 관리
	보안장비 정책 백업 설정
개요	
점검 내용	보안 장비 설정 정보가 저장된 파일을 백업하는지 점검
점검 목적	보안 장비 설정 파일의 백업 유무를 점검하여 보안 장비 또는 보안 장비와 연결된 정보시스템에 문제(장비 이상으로 인해 장비를 교체할 경우, 보안 장비 설정을 실수로 잘못 변경하여 문제가 생긴 경우, 비인가자의 공격 및 침입에 의한 설정 변경 및 삭제 등의 침해사고가 발생했을 경우 등) 발생 시 백업된 설정 파일을 통해 즉시 복구할 수 있도록 대비하고 있는지 확인하기 위함
보안 위협	설정 파일을 백업해놓지 않으면 보안 장비에 문제 발생 시 즉시 설정 복구가 되지 않아 보안 장비에 연결된 정보시스템의 가용성(예: 웹 서버 서비스 불가)에 영향을 미칠 수 있는 위험이 존재함
참고	※ 보안 장비 설정 파일: 보안 장비의 각종 설정 및 정책(룰셋)이 저장된 파일. 보안 장비가 문제가 발생했을 경우 복구하는 용도로 활용
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 보안 장비에 적용된 정책을 별도의 파일로 보관하고 있는 경우
	취약 : 보안 장비에 적용된 정책을 별도의 파일로 보관하고 있지 않은 경우
조치 방법	보안 장비에 적용된 정책을 별도의 파일로 보관
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비에 적용된 정책을 별도의 파일로 보관하는지 확인

Step 2) 보안 장비 설정 메뉴에서 정책 백업 설정. 별도의 파일로 보관

백업 파일 비밀번호

●●●●●●●●

백업 일정

보관 일수

30

일

[지금 백업하기](#)

[정책 백업 설정]

※ 각 벤더마다 설정 방법 상이

04. 보안 장비

S-13 (중)	보안 장비 > 4. 로그 관리
	원격 로그 서버 사용
개요	
점검 내용	보안 장비 원격 로그 설정((r)syslog)이 기관 정책에 맞게 설정되어 있으며 보안 장비 로그를 원격 로그 서버에 별도로 보관하도록 설정되어 있는지 점검
점검 목적	보안 장비 로그를 별도로 구축된 원격 로그 서버에 기관의 정책에 맞는 로그를 보관하도록 설정되어 있는지를 점검하여 로그 삭제 및 변조에 대비하고 있는지 확인하기 위함
보안 위협	별도의 원격 로그 서버가 구축되어 있지 않거나, 원격 로그 서버에 저장될 로그가 기관 정책에 맞게 설정되어 있지 않을 경우, 비인가자의 공격 및 침입 사고 또는 보안 장비 문제 발생 시 로그가 삭제되거나 변조되어 사고 원인 분석이 어려운 위험이 존재함
참고	※ 원격 로그 서버 : 정보시스템(서버, 네트워크, 보안 장비 등)의 로그를 통합적으로 보관하는 서버
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 별도의 원격 로그 서버가 구축되어 있고, 원격 로그 서버에 저장될 로그가 기관 정책에 맞게 설정된 경우
	취약 : 별도의 원격 로그 서버가 구축되어 있지 않거나, 원격 로그 서버에 저장될 로그가 기관 정책에 맞게 설정되지 않은 경우
조치 방법	기관 정책에 맞게 원격 로그 서버에 저장될 로그 설정 후 보안 장비 로그 설정 메뉴에서 (r)syslog 설정 또는 주기적으로 별도 저장 매체에 백업((r)syslog 미지원일 경우)
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비 로그 설정 메뉴에서 syslog 설정 확인

Step 2) 원격 syslog 로그 수집 서버 설정

Step 3) 로컬에서 별도의 저장매체를 통해 수동으로 로그 백업(syslog를 지원하지 않는 경우)

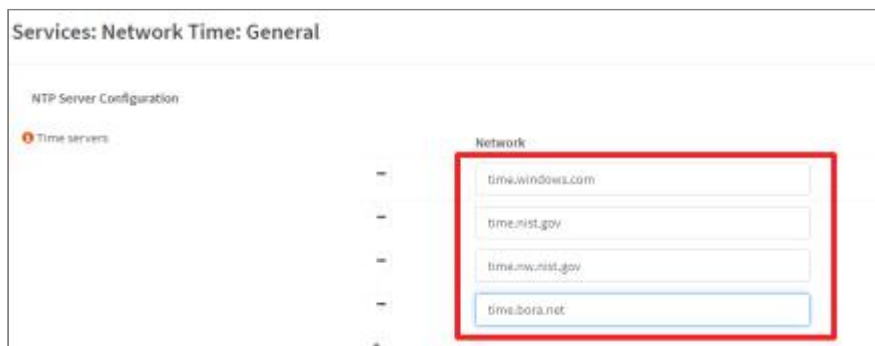
S-14 (중)	보안 장비 > 4. 로그 관리
	NTP 및 시간 동기화 설정
개요	
점검 내용	보안 장비의 NTP 및 시간 동기화 설정 적용 여부 점검
점검 목적	시스템 운영 또는 보안 사고 발생으로 인한 로그 분석 과정에서 이벤트 간의 인과 관계 파악에 도움을 주고 로그 자체의 신뢰성을 갖기 위함
보안 위협	NTP 및 시간 동기화 설정이 되어있지 않을 경우, 시스템 간 시간 동기화 미흡으로 보안 사고 및 장애 발생 시 로그에 대한 신뢰도가 떨어질 위험이 존재함
참고	※ NTP(Network Time Protocol) : 네트워크를 통해 컴퓨터 시스템 간의 시간을 정확하게 유지하기 위한 네트워크 프로토콜. NTP는 1985년 RFC958로 제안된 표준으로 현재 RFC5905 NTP version 4로 대체됨 ※ https://tools.ietf.org/html/rfc5905 NTP 관련 정보 참고 사이트
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : NTP 및 시간 동기화 설정이 되어 있는 경우
	취약 : NTP 및 시간 동기화 설정이 되어 있지 않은 경우
조치 방법	보안 장비 시간 설정에서 NTP 및 시간 동기화 설정 확인
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비 설정 메뉴에서 NTP 프로토콜 연동 확인 및 벤더사에 문의

Step 2) 보안 장비 설정 메뉴에서 NTP 서버 연동 설정



[NTP 설정]

04. 보안 장비

S-15 (상)	보안 장비 > 5. 기능 관리
	정책 관리
개요	
점검 내용	보안 장비 정책에 미사용 및 중복된 정책이 존재하는지 점검
점검 목적	주기적인 정책 검토를 통해 미사용 및 중복된 정책을 제거하여 향후 발생할 수 있는 보안 위협을 제거하고 보안 장비의 고가용성을 유지하기 위함
보안 위협	미사용 및 중복된 정책을 제거하지 않을 경우, 보안 장비 관리자의 업무 편의성 및 효율성이 저하되며 설정되어있는 정책 중 관리자가 인지하지 못한 정책으로 인해 네트워크 보안 체계가 약화 될 위험이 존재함
참고	※ 발생할 수 있는 보안 위협 : 비인가자의 네트워크 접근 및 내부 정보 유출, 악성코드 삽입 등
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 정책에 대한 주기적인 검사로 미사용 및 중복된 정책을 확인하고 제거된 경우
	취약 : 정책에 대한 주기적인 검사를 하지 않고 미사용 및 중복된 정책을 확인 및 제거되지 않은 경우
조치 방법	정책에 대한 주기적인 검사로 미사용 및 중복된 정책을 확인하여 제거
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 정책에 대한 주기적인 검사로 미사용 & 중복된 정책 확인

Step 2) 보안 장비 정책의 주기적인 검사 및 미사용 & 중복된 정책 제거

Step 3) 정책 관리 방법

1. 보안 장비 정책 입력 시 IP 대신 이름을 사용하도록 함
(예시. 그룹명: 000 부서, 000 팀, 000 팀의 000 등)
2. 공통 정책은 그룹으로 관리하도록 함
3. 사용빈도가 높은 정책은 정책 설정 시 상단에 위치하도록 함
4. 위 내용을 포함한 정책에 대해 주기적으로 점검하도록 함

S-16 (상)	보안 장비 > 5. 기능 관리
	NAT 설정
개요	
점검 내용	외부 공개 필요성이 없는 정보시스템에 NAT 설정 여부를 점검
점검 목적	비인가자가 내부 시스템을 공격하기 위해서는 내부 사설 IP를 알아야 하므로 NAT 설정을 통해 내부 네트워크를 보호할 수 있음
보안 위협	NAT 설정을 하지 않을 경우, 공인 IP를 통해 시스템에 접근이 가능하여 정보 유출, 시스템 파괴, 악성코드 전파 등의 불법적 행위가 발생할 위험이 존재함
참고	※ NAT 사용 목적 1) 인터넷의 공인 IP주소 절약 2) 공공망과 연결되는 사용자들의 고유한 사설망을 침입자들로부터 보호
점검 대상 및 판단 기준	
대상	방화벽, VPN 등
판단 기준	양호 : 외부 공개 필요성이 없는 서버, 단말기 등 정보시스템에 대해 NAT 설정을 적용한 경우
	취약 : 외부 공개 필요성이 없는 서버, 단말기 등 정보시스템에 대해 NAT 설정을 적용하지 않은 경우
조치 방법	외부 공개 필요성이 없는 정보시스템에 대해 공인 IP 지정 여부를 확인하여 사설 IP로 변경한 후 보안 장비에서 NAT 설정을 적용
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 공인 IP 확인 사이트(포털 등)에 접속하여 사용 중인 단말의 IP 확인

Step 2) 대부분의 네트워크 보안 제품들은 NAT 기술을 기본으로 채택하고 있으므로 내부 사설 IP 부여 정책에 맞춰 적용하도록 함

04. 보안 장비

☒ 사용

우선순위

NAT 아이디 5

유형

변환 전 출발지

송신 인터페이스(Max 16)

	인터페이스	변환 후 출발지
☒	eth0 (10.0.0.254/24, 사용) v	IPv4
☒	eth2	

[NAT 설정]

S-17 (상)	보안 장비 > 5. 기능 관리
	DMZ 설정
개요	
점검 내용	내부 네트워크와 외부 서비스 네트워크(DMZ)를 구분하고 있는지 점검
점검 목적	외부 네트워크로 서비스를 제공하는 호스트에서 내부 네트워크로의 접근이 통제되고 있는지 확인하기 위함
보안 위협	DMZ 설정을 통해 내부 네트워크와 외부 서비스 네트워크를 구분하도록 설정되어 있지 않을 경우, 외부 네트워크를 통해서 서비스를 제공받는 악의적인 사용자가 DMZ 내 호스트를 통해 내부 네트워크로 불법적 연결을 시도할 위험이 존재함
참고	※ DMZ : 조직의 내부 네트워크와 외부 네트워크 사이에 위치하는 네트워크 망으로 DMZ 내 컴퓨터는 외부 네트워크에만 연결할 수 있도록 하고, 내부 네트워크로는 연결할 수 없도록 구성함
점검 대상 및 판단 기준	
대상	방화벽, VPN 등
판단 기준	양호 : DMZ를 구성하여 내부 네트워크를 보호하는 경우
	취약 : DMZ를 구성하지 않고 사설망에서 외부 공개 서비스를 제공하는 경우
조치 방법	- DMZ를 구성하여 내부 네트워크와 외부 서비스 네트워크 분리 - 물리적(망 분리)으로 내부 네트워크와 외부 서비스 네트워크가 분리되어 있으면 해당 없음
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 네트워크 구성도 또는 방화벽 설정 확인

Step 2) 방화벽의 옵션 설정

각각의 네트워크는 방화벽에 서로 다른 포트를 사용하여 연결하는데 이를 삼각 방화벽 설정 (three-legged firewall set-up)이라 함

04. 보안 장비

유형	고정 ▼
이름	eth4
Zone	DMZ ▼
IPv4 주소	
IPv6 주소	::/0

[방화벽 옵션 설정]

Step 3) 두 개의 방화벽 사용

DMZ는 두 개의 방화벽 중간에 위치하며, 두 개의 방화벽과 연결됨. 하나의 방화벽은 내부 네트워크와 연결되고 다른 하나는 외부 네트워크와 연결됨. 우연한 설정 실수를 통해 외부 네트워크가 내부 네트워크로 연결할 수 있게 되는 상황을 방지함. 이런 구성 형식을 차단된 서브넷 방화벽(screened-subnet firewall) 이라고 함

S-18 (상)	보안 장비 > 5. 기능 관리
	최소한의 서비스만 제공
개요	
점검 내용	보안 장비에서 필요한 서비스만 제공하고 있는지 점검
점검 목적	보안 장비 정책을 검토하여 사용하지 않는 IP와 포트를 제거하여 네트워크 및 시스템 운영의 보안성을 유지하기 위함
보안 위협	최소한의 서비스만 제공하지 않을 경우, 비인가자의 침입 또는 악성 소프트웨어 전달 등의 보안 위협이 발생할 위험이 존재함
참고	※ 방화벽 기본 정책: 방화벽은 기본적으로 All Deny 설정을 적용하며 허용할 IP와 포트만 추가함으로써 관리 포인트를 최소화함
점검 대상 및 판단 기준	
대상	방화벽, VPN, 웹 방화벽 등
판단 기준	양호 : All Deny 설정 및 보안 장비에 최소 서비스만 허용하는 경우
	취약 : All Deny 미설정 또는 보안 장비에 불필요한 서비스를 허용하는 경우
조치 방법	보안 장비에 최소 서비스만 허용하도록 설정함
조치 시 영향	허용되지 않은 접속은 모두 차단됨

점검 및 조치 사례

● 공통

Step 1) 방화벽에서 허용되지 않은 포트 접속 확인

Step 2) 방화벽 기본 정책인 all deny에 최소 서비스만 허용 확인

(허용된 IP와 서비스 포트만 오픈, 모든 IP 및 서비스 허용 금지)



Protocol	Source IP	Destination IP	Port	Action
IPv4 TCP	1.1.1.1	*	443 (HTTPS)	Allow
IPv4 UDP	2.2.2.2	*	153	Allow
IPv4 *	*	*	*	Deny

[방화벽 정책 설정]

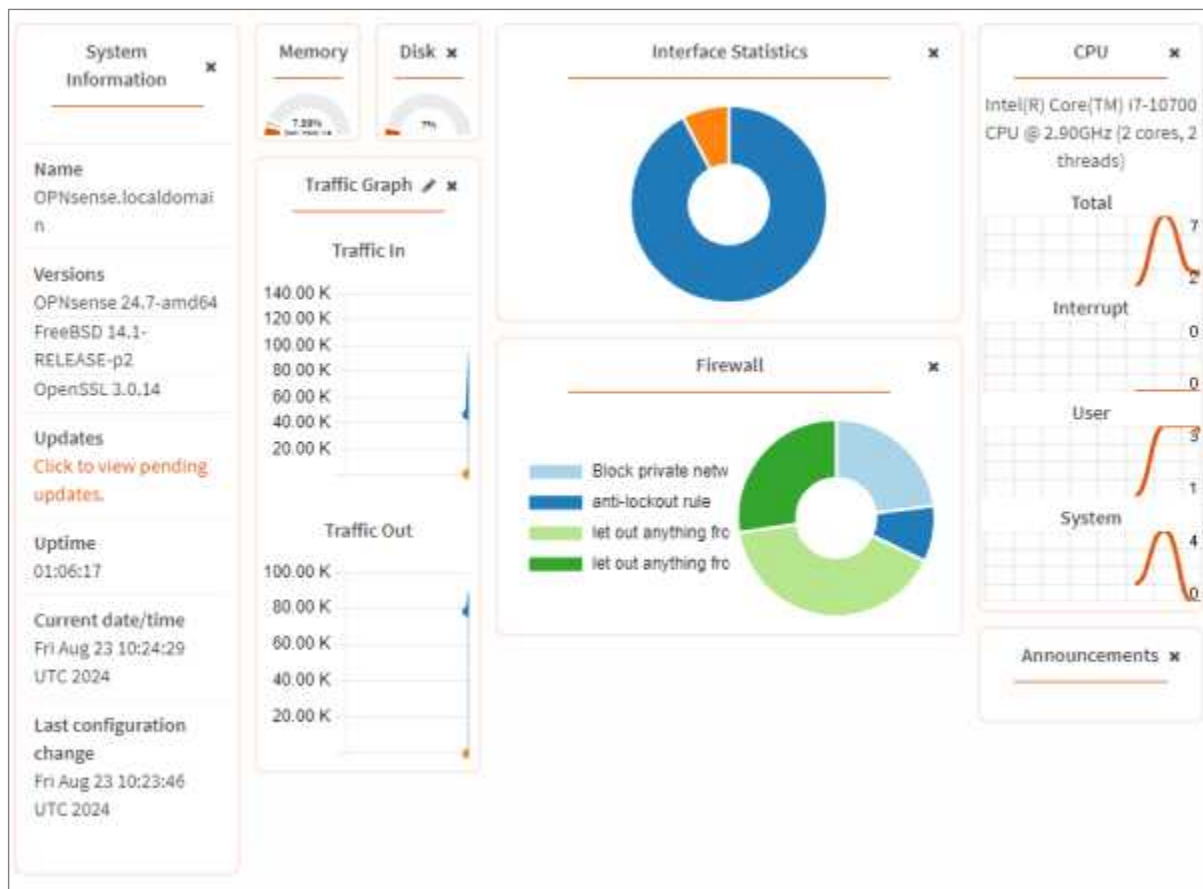
04. 보안 장비

S-19 (상)	보안 장비 > 5. 기능 관리
	이상징후 탐지 모니터링 수행
개요	
점검 내용	보안 장비에 이상징후 탐지 모니터링을 수행하고 있는지 점검
점검 목적	이상징후가 탐지되는 경우 사고 예방 및 신속한 조치를 이행하기 위함
보안 위협	이상징후 탐지 모니터링을 수행하지 않을 경우, 보안 사고를 미리 방지할 수 없는 위험이 존재함
참고	※ 보안 사고 미연 방지 및 IT 컴플라이언스 준수 예시 1) 휴일 또는 업무 시간 이외에 비정상적인 패턴으로 중요 문서 또는 고객 정보 DB에 접근한다면 정보 유출 징후가 있다고 판단 가능 예시 2) 퇴사 징후가 의심되는 직원이 휴일이나 업무 시간 외에 비정상적으로 중요 문서나 고객 DB에 접근하는 경우 정보 유출 가능성이 커 이를 사전에 탐지하고 예방할 수 있음
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 이상징후 탐지 모니터링을 수행하고 있는 경우
	취약 : 이상징후 탐지 모니터링을 수행하고 있지 않은 경우
조치 방법	이상징후 탐지 시 담당자/관리자가 즉시 확인할 수 있도록 모니터링 수행
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

- Step 1) 보안 장비의 이상징후 탐지 모니터링 기능(알람, 이메일, SMS 등)이 설정되어 담당자가 즉시 인지할 방안이 있는지를 점검
- Step 2) 장비 자체 기능 대신 Syslog를 통해 모니터링 시스템으로 전송하는 경우, 해당 시스템의 모니터링 기능 설정 여부를 점검
- Step 3) 보안 장비 이상징후에 대해 실시간 모니터링 실시



[보안 장비 모니터링]

04. 보안 장비

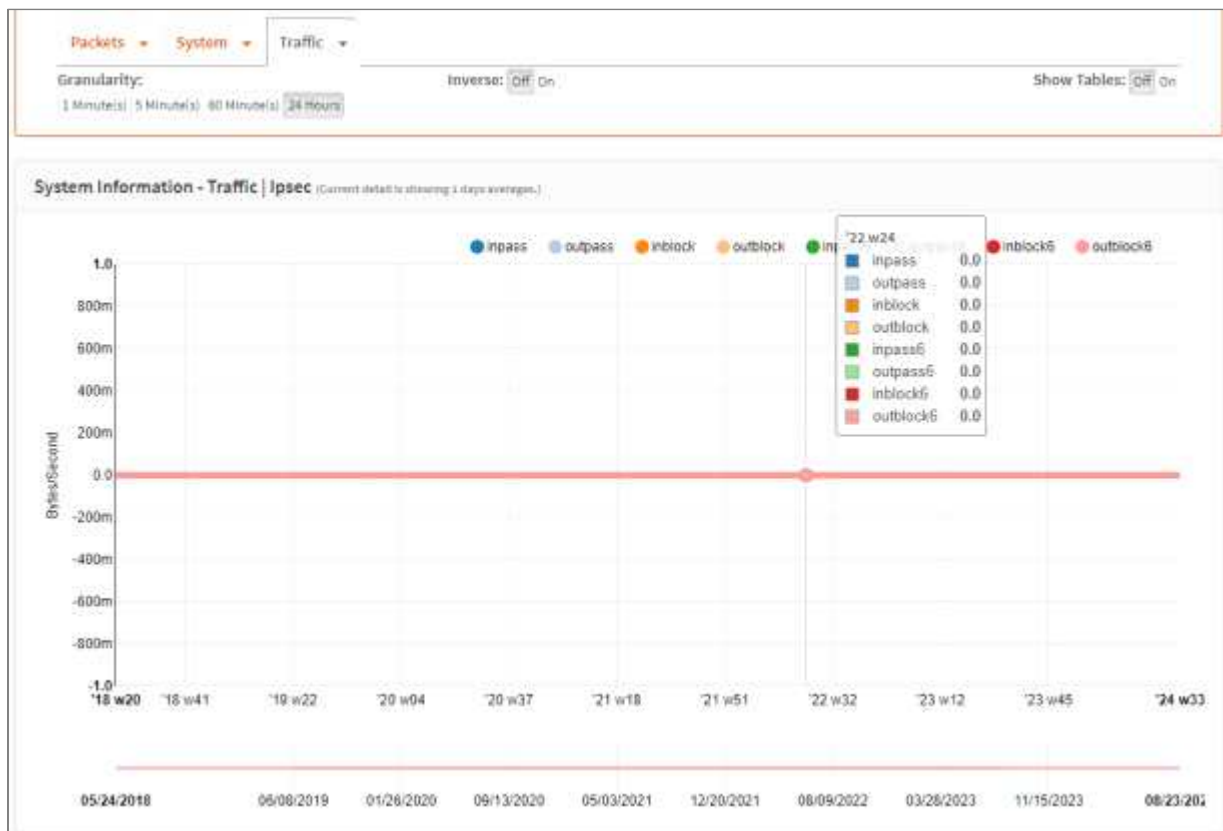
S-20 (상)	보안 장비 > 5. 기능 관리
	장비 사용량 검토
개요	
점검 내용	보안 장비에서 제공하는 Dashboard를 통해 보안 장비의 가용성에 대한 실시간 검토 여부 점검
점검 목적	보안 장비의 가용성에 대한 검토로 인해 네트워크 트래픽의 수준을 파악하게 되고, 그에 따른 가용성 향상을 고려할 수 있음
보안 위협	보안 장비 가용성을 정기적으로 검토를 하지 않을 경우, 성능 및 회선 상태를 파악할 수 없어 보안 장비의 가용성 하락이 발생할 위험이 존재함
참고	※ 내부 정책에 맞게 일, 주, 월 등의 주기를 정하여 정기적으로 이행하도록 하며 일반적으로 월 1회 검토를 권고함
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 보안 장비 가용성을 정기적으로 모니터링 및 검토할 경우
	취약 : 보안 장비 가용성을 정기적으로 모니터링 및 검토하지 않을 경우
조치 방법	장비 사용량을 정기적으로 모니터링
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비 사용량에 대해 정기적인 모니터링 및 검토 여부 확인

Step 2) 보안 장비의 Web Dash Board 모니터링 및 정기적인 장비 사용량 검토(정기점검보고서, 검토보고서 등)



[장비 사용량 검토]

04. 보안 장비

S-21 (상)	보안 장비 > 5. 기능 관리
	SNMP 서비스 확인
개요	
점검 내용	SNMP 서비스 사용 여부 점검
점검 목적	보안 장비 관리를 위해 NMS 솔루션과의 연동으로 SNMP 서비스 사용이 필요한 경우가 아니라면 서비스를 중지하도록 함
보안 위협	불필요한 SNMP 서비스를 사용할 경우, DoS 공격, 보안 장비 성능 저하, 크래쉬, 리로드 등의 공격 위험이 존재함
참고	※ SNMP 서비스 : 네트워크 관리를 위한 프로토콜로 네트워크상의 서버, 프린터, 허브, 스위치, 라우터와 같은 네트워크 장치를 구성하고 정보를 수집하는 데 사용됨 ※ SNMP 서비스를 이용해야 하는 경우 Community String을 유추할 수 없게 설정
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 불필요한 SNMP 서비스를 사용하지 않을 경우
	취약 : 불필요한 SNMP 서비스를 사용할 경우
조치 방법	불필요한 경우 SNMP 서비스 중지
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비의 SNMP 설정 메뉴에서 확인

Step 2) 불필요하다면 SNMP 서비스를 중지하고, 관리를 위해 NMS 솔루션과의 연동이 필요하다면 SNMP 설정

SNMP	
☒ SNMP 사용	MIB 다운로드
SNMP 커뮤니티 (Max 10)	
이름	IP/CIDR
☒	IPv4/CIDR
☒ KISA123!@#	1.1.1.1 / 32

[SNMP 설정]

S-22 (상)	보안 장비 > 5. 기능 관리
	SNMP Community String 복잡성 설정
개요	
점검 내용	SNMP Community String이 유추하기 어렵게 설정되어 있는지 점검
점검 목적	SNMP Community String을 유추하기 어렵게 설정하여 네트워크상에서 시스템 정보가 비인가자에게 노출되지 않도록 함
보안 위협	SNMP의 Community String을 기본값 또는 유추하기 쉬운 값으로 설정할 경우, 악의적인 사용자가 장비 설정을 쉽게 변경(RW)하여 중요 시스템 정보가 노출될 수 있는 위험이 존재함
참고	※ SNMP 버전: v1, v2, v3 이 존재. v1, v2는 Community String을 평문 전송하지만, v3는 암호화가 설정되어 해시값으로 전송함
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : SNMP 서비스를 사용하지 않거나, 유추하기 어려운 Community String을 설정한 경우
	취약 : Community String을 기본값으로 사용하고 있거나, 유추하기 쉬운 Community String을 설정한 경우
조치 방법	유추하기 어려운 Community String을 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 보안 장비의 SNMP 설정 메뉴에서 Community String 확인

Step 2) 보안 장비는 SNMP 취약성이 존재하므로 누구나 추측하기 어렵고 의미가 없는 문자열, 영문자 혼합으로 변경

SNMP		
☒ SNMP 사용 MIB 다운로드		
SNMP 커뮤니티 (Max 10)		
☒		IP/CIDR
☒		IPv4/CIDR
☐	KISA123!@#	1.1.1.1 / 32

[SNMP Community String 설정]

04. 보안 장비

S-23 (중)	보안 장비 > 5. 기능 관리
	유해 트래픽 탐지/차단 정책 설정
개요	
점검 내용	유해 트래픽 탐지/차단 정책 적용 여부 점검
점검 목적	유해 트래픽(Flooding 공격, Scan 공격, 해킹 툴 공격 등)을 탐지/차단 정책을 적용하여 네트워크 운영 및 서비스의 장애 발생 가능성을 차단하기 위함
보안 위협	유해 트래픽 탐지/차단 정책이 설정되지 않을 경우, 악성코드가 네트워크를 통해 전파될 우려가 있음
참고	※ Flooding 공격 : 악의적으로 한꺼번에 많은 양의 데이터를 보내 상대방의 서비스를 운용할 수 없게 만드는 서비스 거부 공격 ※ Scan 공격 : 네트워크, 시스템의 활성화된 포트·서비스·취약점을 식별하기 위한 행위 ※ 해킹툴 공격 : 공격자가 상용 해킹툴이나, 자체 제작한 해킹툴을 이용해 시스템을 침투·장악하거나 권한을 획득하는 행위
점검 대상 및 판단 기준	
대상	방화벽, VPN, IDS, IPS, Anti-DDoS, 웹 방화벽 등
판단 기준	양호 : 유해 트래픽 탐지/차단 패턴이 적용된 경우
	취약 : 유해 트래픽 탐지/차단 패턴이 적용되지 않은 경우
조치 방법	유해 트래픽 탐지/차단 정책 설정
조치 시 영향	오탐으로 인한 차단 정책 설정 시 서비스 영향 발생

점검 및 조치 사례

● Flooding 공격

- Step 1) TCP/UDP/ICMP Flooding 공격에 대한 탐지 및 차단 패턴 적용 여부를 점검
- Step 2) 인터넷 진입구간에 위치한 DDoS 차단시스템에 TCP/UDP/ICMP Flooding 공격에 대한 차단정책 등록 여부를 점검
- Step 3) TCP/UDP/ICMP Flooding 공격에 대한 탐지 및 차단 패턴 적용
- Step 4) 인터넷 진입구간에 위치한 DDoS 차단시스템에 TCP/UDP/ICMP Flooding 공격에 대한 차단 정책 등록

● Scan 공격

- Step 1) Port Scan에 대한 탐지 및 차단 패턴 적용 여부를 점검
- Step 2) 인터넷 진입 구간에 위치한 DDoS 차단시스템에 Port Scan에 대한 차단 정책 등록 여부를 점검

Step 3) Port Scan에 대한 탐지 및 차단 패턴 적용

Step 4) 인터넷 진입 구간에 위치한 DDoS 차단시스템에 Port Scan에 대한 차단 정책 등록 여부를 점검

● 해킹툴 공격

Step 1) 악성코드에 대한 탐지 및 차단 패턴 적용 여부를 점검

Step 2) 주요 해킹 툴에 대한 탐지 및 차단정책 등록

☐		사용	200040401	Win32/Bagz.worm.155140-zip-MIME-AHN	MassMailer		높음	패킷 차단
☐		사용	200040402	Win32/Bagz.worm.155140-MIME1-AHN	MassMailer		높음	패킷 차단
☐		사용	200040403	Win32/Bagz.worm.155140-MIME2-AHN	MassMailer		높음	패킷 차단
☐		사용	200040404	Win32/Bagz.worm.155140-MIME3-AHN	MassMailer		높음	패킷 차단
☐		사용	200040501	Win32/Netsky.worm.29568-AHN	MassMailer		높음	패킷 차단
☐		사용	200040502	Win32/Netsky.worm.29568-ZIP-AHN	MassMailer		높음	패킷 차단
☐		사용	200040701	Win32/Bagz.worm.70147-zip-MIME-AHN	MassMailer		높음	패킷 차단
☐		사용	200040702	Win32/Bagz.worm.70147-MIME1-AHN	MassMailer		높음	패킷 차단
☐		사용	200040703	Win32/Bagz.worm.70147-MIME2-AHN	MassMailer		높음	패킷 차단
☐		사용	200040704	Win32/Bagz.worm.70147-MIME3-AHN	MassMailer		높음	패킷 차단
☐		사용	200040801	Win32/Mytob.worm.59006-IRC-AHN	MassMailer		높음	패킷 차단
☐		사용	200040802	Win32/Mytob.worm.59006-zip-MIME-AHN	MassMailer		높음	패킷 차단
☐		사용	200040803	Win32/Mytob.worm.59006-MIME1-AHN	MassMailer		높음	패킷 차단
☐		사용	200040804	Win32/Mytob.worm.59006-MIME2-AHN	MassMailer		높음	패킷 차단

[차단 정책 예시]